

ĐẠI HỌC QUỐC GIA TP.HCM

TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN



**ĐỒ ÁN MÔN HỌC
AN TOÀN MẠNG**

**BÁO CÁO ỦNG PHÓ SỰ CỐ VÀ
BÀI HỌC KINH NGHIỆM**

BLUE TEAM

Giảng viên hướng dẫn – TS. Lê Kim Hùng

Sinh viên thực hiện:

23520552 – Phan Cảnh Đăng Huân
23520479 – Lê Đình Hiếu

Mục lục

Báo cáo sự cố	3
Case Study 1: Ngăn chặn tấn công thực thi mã từ xa (RCE) qua lỗ hổng Shellshock	3
Case Study 2: Ngăn chặn cuộc tấn công DDOS / Botnet	4
Case Study 3: Ngăn chặn cuộc tấn công từ nội bộ	5
Case Study 4: Ngăn chặn leo thang đặc quyền qua Docker	6
Hành động ứng phó & Khắc phục	7
Case Study 5: Lộ thông tin nhạy cảm qua Spring Boot Actuator	7
Hành động ứng phó	8
Case Study 6: Kiểm soát truy cập và mã hóa dữ liệu File Server	8
Hành động ứng phó	9
Case Study 7: Khắc phục lỗi mất đồng bộ thời gian	12
Hành động ứng phó	13
Bài học kinh nghiệm	14
Bài học về kiến trúc mạng & Zero Trust	14
Bài học về bảo mật ứng dụng & cập nhật	14
Bài học về gia cố hệ thống	14
Bài học về giám sát & phản ứng	15

BÁO CÁO SỰ CỐ

Ở phần báo cáo sự cố, Blue Team xin chọn lọc và phân tích các cuộc tấn công và lỗi cấu hình nghiêm trọng nhất.

Case Study 1: Ngăn chặn tấn công thực thi mã từ xa (RCE) qua lỗ hổng Shellshock

Tình huống: Vào lúc 16:54 ngày 09/12/2025, hệ thống phát hiện một nỗ lực tấn công nguy hiểm từ IP 172.20.10.3. Attacker không dò quét bình thường mà gửi thẳng một đoạn mã khai thác vào Web Server.

>	Dec 9, 2025 @ 04:54:16.335	008	dmz-reverseproxy-waf	T1083	Discovery	ModSecurity rejected a query	7	31333
>	Dec 9, 2025 @ 04:54:16.292	008	dmz-reverseproxy-waf	T1068 T1190	Privilege Escalation, Initial Access	Shellshock attack attempt	6	31166

Phân tích kỹ thuật:

Payload được chèn vào HTTP header có dạng () { : };. Đây là dấu hiệu của lỗ hổng Shellshock (CVE-2014-6271), cho phép Attacker thực thi lệnh Linux bất kỳ với quyền Web Server.

Mức độ nguy hiểm: Critical. Nếu thành công, Attacker sẽ chiếm quyền điều khiển Server.

CVE-2014-6271 PUBLISHED [View JSON](#) | [User Guide](#)

[Collapse all](#)

Required CVE Record Information

CNA: Debian GNU/Linux

Published: 2014-09-24 **Updated:** 2021-11-05

Description

GNU Bash through 4.3 processes trailing strings after function definitions in the values of environment variables, which allows remote attackers to execute arbitrary code via a crafted environment, as demonstrated by vectors involving the ForceCommand feature in OpenSSH sshd, the mod_cgi and mod_cgid modules in the Apache HTTP Server, scripts executed by unspecified DHCP clients, and other situations in which setting the environment occurs across a privilege boundary from Bash execution, aka "ShellShock." NOTE: the original fix for this issue was incorrect; CVE-2014-7169 has been assigned to cover the vulnerability that is still present after the incorrect fix.

Hành động ứng phó:

1. **Phát hiện:** Suricata phát hiện chữ ký tấn công trong gói tin TCP và cảnh báo mức 1 (cao nhất).

2. Chặn đứng: ModSecurity (WAF) đóng vai trò bảo vệ, phân tích thấy payload vi phạm và lập tức từ chối kết nối (HTTP 403 Forbidden) trước khi payload làm hại đến Server.

Last 250 Alert Entries. (Most recent entries are listed first)										
Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
12/09/2025 16:54:12		2	TCP	Attempted Information Leak	172.20.10.2	80	172.20.10.3	35324	1:2101201	GPL WEB_SERVER 403 Forbidden
12/09/2025 16:54:12		1	TCP	Attempted Administrator Privilege Gain	172.20.10.3	35324	172.20.10.2	80	1:2022028	ET WEB_SERVER Possible CVE-2014-6271 Attempt

Kết quả: Hệ thống an toàn và payload bị vô hiệu hóa.

Case Study 2: Ngăn chặn cuộc tấn công DDOS / Botnet

Tình huống: 14:45 ngày 04/12/2025, hệ thống bắt ngờ ghi nhận sự gia tăng đột biến lưu lượng kết nối từ hàng loạt IP Public khác nhau (194.239.x.x, 198.90.x.x, ...) trong thời gian ngắn.

194.239.118.243		12/04/2025 14:45:36	SURICATA STREAM 3way handshake wrong seq wrong ack	1:2210010	
198.90.180.54		12/04/2025 14:45:36	SURICATA STREAM 3way handshake wrong seq wrong ack	1:2210010	
218.222.31.169		12/04/2025 14:45:36	SURICATA STREAM 3way handshake wrong seq wrong ack	1:2210010	
65.114.49.224		12/04/2025 14:45:38	SURICATA STREAM 3way handshake wrong seq wrong ack	1:2210010	
159.9.172.72		12/04/2025 14:45:38	SURICATA STREAM 3way handshake wrong seq wrong ack	1:2210010	
145.150.85.107		12/04/2025 14:45:38	SURICATA STREAM 3way handshake wrong seq wrong ack	1:2210010	
190.128.94.239		12/04/2025 14:45:38	SURICATA STREAM 3way handshake wrong seq wrong ack	1:2210010	
42.239.19.222		12/04/2025 14:45:38	SURICATA STREAM 3way handshake wrong seq wrong ack	1:2210010	
205.184.109.240		12/04/2025 14:45:38	SURICATA STREAM 3way handshake wrong seq wrong ack	1:2210010	
142.72.231.229		12/04/2025 14:45:38	SURICATA STREAM 3way handshake wrong seq wrong ack	1:2210010	
107.160.184.32		12/04/2025 14:45:38	SURICATA STREAM 3way handshake wrong seq wrong ack	1:2210010	
32.224.44.149		12/04/2025 14:45:38	SURICATA STREAM 3way handshake wrong seq wrong ack	1:2210010	
159.156.7.136		12/04/2025 14:45:38	SURICATA STREAM 3way handshake wrong seq wrong ack	1:2210010	
163.94.218.11		12/04/2025 14:45:38	SURICATA STREAM 3way handshake wrong seq wrong ack	1:2210010	
183.110.130.159		12/04/2025 14:45:38	SURICATA STREAM 3way handshake wrong seq wrong ack	1:2210010	
72.155.230.89		12/04/2025 14:45:38	SURICATA STREAM 3way handshake wrong seq wrong ack	1:2210010	
40.160.159.202		12/04/2025 14:45:38	SURICATA STREAM 3way handshake wrong seq wrong ack	1:2210010	
203.22.6.130		12/04/2025 14:45:38	SURICATA STREAM 3way handshake wrong seq wrong ack	1:2210010	
160.211.10.127		12/04/2025 14:45:38	SURICATA STREAM 3way handshake wrong seq wrong ack	1:2210010	

Phân tích kỹ thuật:

- Các gói tin gửi đến đều bị lỗi **Wrong Seq/Ack**.
- Đây là dấu hiệu của kỹ thuật **TCP Spoofing** từ mạng Botnet. Attacker giả mạo IP nguồn để làm tràn bảng trạng thái kết nối (State Table) của Firewall, nhằm gây quá tải hệ thống.

Hành động ứng phó:

1. Wazuh tự động gom các log chặn rồi rác từ Firewall thành một cảnh báo duy nhất (**Rule ID 87702**), giúp Blue Team nhận diện đây là tấn công có quy mô chứ không đơn giản là sự cố lẻ tẻ.

Security Alerts							
Time ↓	Agent	Agent name	Technique(s)	Tactic(s)	Description	Level	Rule ID
> Dec 4, 2025 @ 02:44:23.646	000	h4rrybrwniewazuh	T1110	Credential Access	Multiple pfSense firewall blocks events from same source.	10	87702
> Dec 4, 2025 @ 02:39:22.091	000	h4rrybrwniewazuh	T1110	Credential Access	Multiple pfSense firewall blocks events from same source.	10	87702

2. Suricata và pfSense tự động Drop các gói tin nghi ngờ, không để chúng tiêu tốn tài nguyên xử lý của Web Server.

Sync

IP Lists

Blocked Hosts Log View Settings

Save or Remove Hosts

Download

Clear

All blocked hosts will be saved

All blocked hosts will be cleared

Save Settings

Save

Refresh

500

Save auto-refresh and view settings

Default is ON

Number of blocked entries to view.

Default is 500

Last 500 Hosts Blocked by Suricata

Note: Only blocked IP addresses from Legacy Mode interfaces are shown! For inline IPS mode interfaces, dropped IP addresses are highlighted on the ALERTS tab.

Blocked IP	Block Date/Time	Block Alert Description	Block Rule GID:SID	Remove Block
172.20.10.7	12/04/2025 14:39:45	SURICATA STREAM 3way handshake SYN resend different seq on SYN recv	1:2210008	✖
	12/04/2025 14:11:05	SURICATA HTTP Unexpected Request body	1:2221045	
	12/04/2025 14:04:27	SURICATA HTTP Host header invalid	1:2221028	
	12/04/2025 14:39:59	SURICATA STREAM 3way handshake SYN resend different seq on SYN recv	1:2210008	
	12/04/2025 14:39:55	SURICATA STREAM 3way handshake SYN resend different seq on SYN recv	1:2210008	
	12/04/2025 14:39:52	SURICATA STREAM 3way handshake SYN resend different seq on SYN recv	1:2210008	
	12/04/2025 14:39:47	SURICATA STREAM 3way handshake SYN resend different seq on SYN recv	1:2210008	
	12/04/2025 14:39:21	SURICATA STREAM 3way handshake SYN resend different seq on SYN recv	1:2210008	
	12/03/2025 13:42:17	SURICATA Applayer Mismatch protocol both directions	1:2260000	

Kết quả: Dịch vụ Web vẫn hoạt động bình thường, không bị gián đoạn.

Case Study 3: Ngăn chặn cuộc tấn công từ nội bộ

Tình huống: Vào lúc 21:44 ngày 08/12/2025, máy tính nhân viên 192.168.40.10 (thuộc vùng mạng LAN30) bất ngờ thực hiện các hành vi bất thường như quét hàng loạt các cổng 23, 445, 139 ở các vùng mạng khác (LAN40).

Last 500 Firewall Log Entries. (Maximum 500)						
Action	Time	Interface	Rule	Source	Destination	Protocol
✗	Dec 8 21:44:08	LAN30	(@131)	192.168.40.10:33006	192.168.50.3:1025	TCP:S
✗	Dec 8 21:44:08	LAN30	(@131)	192.168.40.10:33006	192.168.50.4:23	TCP:S
✗	Dec 8 21:44:08	LAN30	(@131)	192.168.40.10:33006	192.168.50.7:110	TCP:S
✗	Dec 8 21:44:08	LAN40	(@139)	192.168.50.10:57352	8.8.8.8:53	TCP:S
✗	Dec 8 21:44:09	LAN30	(@131)	192.168.40.10:33007	192.168.50.2:587	TCP:S
✗	Dec 8 21:44:09	LAN30	(@131)	192.168.40.10:33007	192.168.50.0:21	TCP:S
✗	Dec 8 21:44:09	LAN30	(@131)	192.168.40.10:33007	192.168.50.3:1025	TCP:S
✗	Dec 8 21:44:09	LAN30	(@131)	192.168.40.10:33007	192.168.50.4:23	TCP:S
✗	Dec 8 21:44:09	LAN30	(@131)	192.168.40.10:33007	192.168.50.1:8080	TCP:S
✗	Dec 8 21:44:09	LAN30	(@131)	192.168.40.10:33007	192.168.50.60:110	TCP:S
✗	Dec 8 21:44:09	LAN30	(@131)	192.168.40.10:33007	192.168.50.62:8080	TCP:S
✗	Dec 8 21:44:09	LAN30	(@131)	192.168.40.10:33007	192.168.50.61:135	TCP:S
✗	Dec 8 21:44:09	LAN30	(@131)	192.168.40.10:33007	192.168.50.63:256	TCP:S
✗	Dec 8 21:44:09	LAN30	(@131)	192.168.40.10:33007	192.168.50.7:110	TCP:S
✗	Dec 8 21:44:09	LAN40	(@139)	192.168.50.20:58196	8.8.8.8:53	TCP:S
✗	Dec 8 21:44:10	LAN20	Default deny rule IPv4 (1000000103)	192.168.30.10:47662	8.8.8.8:53	TCP:S
✗	Dec 8 21:44:10	LAN30	(@131)	192.168.40.10:33006	192.168.50.15:139	TCP:S
✗	Dec 8 21:44:10	LAN30	(@131)	192.168.40.10:33006	192.168.50.16:21	TCP:S
✗	Dec 8 21:44:10	LAN30	(@131)	192.168.40.10:33006	192.168.50.17:1025	TCP:S

Phân tích kỹ thuật:

- Đây không phải hành vi của người dùng bình thường. Việc quét các cổng Telnet, SMB cho thấy máy tính này có thể đã bị nhiễm mã độc và đang cố gắng kết nối đến các phân vùng mạng khác.

Hành động ứng phó:

- Hệ thống Firewall đã được cấu hình theo mô hình Zero Trust. Dù xuất phát từ mạng nội bộ, các kết nối vẫn bị chặn do không nằm trong danh sách Whitelist.

Kết quả: Mã độc bị cô lập tại LAN30, không thể lây sang LAN40.

Case Study 4: Ngăn chặn leo thang đặc quyền qua Docker

Tình huống: Vào ngày 12/12/2025, Red Team phát hiện tài khoản người dùng thường h4rrybrwnie trên Web Server (LAN10) có khả năng thực thi lệnh Docker với quyền root. Kẻ tấn công đã lợi dụng điều này để mount toàn bộ ổ cứng máy chủ thật (/) vào container và chiếm quyền điều khiển hệ thống (Host OS).

Phân tích kỹ thuật:

- User h4rrybrwnie nằm trong nhóm docker, tương đương với quyền root không cần mật khẩu.

- **Lệnh tấn công:** `docker run -v /:/host ...` cho phép ghi đè file hệ thống, đọc file `/etc/shadow`.

```
h4rrybrwnie@lan10-webserver:~$ docker run -it --rm -v /:/host --user 0 --entrypoint sh webgoat/webgoat
# cat /host/etc/shadow
root:*:20305:0:99999:7:::
daemon:*:20305:0:99999:7:::
bin:*:20305:0:99999:7:::
sys:*:20305:0:99999:7:::
sync:*:20305:0:99999:7:::
games:*:20305:0:99999:7:::
man:*:20305:0:99999:7:::
lp:*:20305:0:99999:7:::
mail:*:20305:0:99999:7:::
news:*:20305:0:99999:7:::
uucp:*:20305:0:99999:7:::
proxy:*:20305:0:99999:7:::
www-data:*:20305:0:99999:7:::
backup:*:20305:0:99999:7:::
list:*:20305:0:99999:7:::
irc:*:20305:0:99999:7:::
lapt:*:20305:0:99999:7:::
nobody:*:20305:0:99999:7:::
systemd-networkd:*:20305:0:99999:7:::
systemd-timesyncd:*:20305:0:99999:7:::
dhcpcd:*:20305:0:99999:7:::
```

Hành động ứng phó & Khắc phục

Thu hồi quyền: Gỡ bỏ user `h4rrybrwnie` khỏi nhóm `docker` ngay lập tức.

```
sudo gpasswd -d h4rrybrwnie docker
```

Cách ly người dùng: Kích hoạt tính năng **usersns-remap** để ánh xạ quyền root trong container thành user `nobody` (không có quyền) trên máy thật.

Thêm vào `/etc/docker/daemon.json` đoạn code bên dưới:

```
{ "usersns-remap": "default" }
```

Xử lý sự cố tương thích: Khi bật **usersns-remap**, Docker bị mất kết nối Internet để tải Image mới. Blue Team đã thực hiện quy trình **Offline Image Transfer** (Lưu image ra file `.tar` và nạp lại thủ công) để hệ thống hoạt động trở lại mà vẫn đảm bảo an toàn.

Kết quả: Kẻ tấn công dù chạy được container cũng bị báo lỗi **Permission Denied** khi cố gắng truy cập file hệ thống máy chủ.

```
h4rrybrwnie@lan10-webserver:~$ sudo docker run -it --rm -v /:/host --user 0 --entrypoint sh webgoat/webgoat
# ls /host/home/h4rrybrwnie
ls: cannot open directory '/host/home/h4rrybrwnie': Permission denied
```

Case Study 5: Lộ thông tin nhạy cảm qua Spring Boot Actuator

Tình huống: Hệ thống giám sát phát hiện các truy cập bất thường từ mạng bên ngoài vào đường dẫn `http://<IP>/WebGoat/actuator/env`. Đây là endpoint quản trị của Spring Boot, làm lộ các biến môi trường, mật khẩu database và cấu hình hệ thống.

Hành động ứng phó

Chặn đứng tại WAF/Proxy: Thay vì vá từng ứng dụng (tốn thời gian), Blue Team đã cấu hình Nginx Reverse Proxy (tại DMZ) để chặn đứng mọi request chứa từ khóa nhạy cảm.

Cấu hình Nginx:

```
location ~* /(actuator|heapdump|loggers|env) {  
    deny all;  
    return 404; # Trả về Not Found để đánh lừa kẻ tấn công  
}
```

Kết quả: Kẻ tấn công không còn khả năng thu thập thông tin hệ thống, giảm thiểu rủi ro bị khai thác sâu hơn.



Case Study 6: Kiểm soát truy cập và mã hóa dữ liệu File Server

Tình huống: Một cuộc kiểm thử xâm nhập nội bộ, bên Red Team cho thấy bất kỳ nhân viên nào trong mạng LAN30 cũng có thể truy cập toàn bộ dữ liệu trên File Server (LAN20) mà không cần mật khẩu (Anonymous Access). Tài khoản nhân viên có quyền sudo không cần thiết. Red team quét lỗ hổng phát hiện phiên bản Samba 4.6.2-Ubuntu trên File Server chứa lỗ hổng nghiêm trọng (CVE-2017-7494). Ngoài ra, dữ liệu truyền tải không được mã hóa, có thể bị nghe lén.

Hành động ứng phó

Tại máy nhân viên thực hiện các thao tác sau để khắc phục:

Xóa quyền sudo mặc định:

```
h4rrybrwnie@h4rrybrwnie:~$ # Xóa user khỏi nhóm sudo
sudo gpasswd -d h4rrybrwnie sudo
[sudo] password for h4rrybrwnie:
```

Tạo user admin nội bộ:

```
h4rrybrwnie@h4rrybrwnie:~$ sudo adduser it_support
Adding user `it_support' ...
Adding new group `it_support' (1001) ...
Adding new user `it_support' (1001) with group `it_support' ...
Creating home directory `/home/it_support' ...
Copying files from `/etc/skel' ...
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for it_support
Enter the new value, or press ENTER for the default
    Full Name []: it_support
    Room Number []: 0123456789
    Work Phone []: 0123456789
    Home Phone []:
    Other []:
Is the information correct? [Y/n] Y
```

Cấp quyền sudo cho it_support:

```
h4rrybrwnie@h4rrybrwnie:~$ groups it_support
it_support : it_support sudo
```

Thiết lập định danh:

- Tạo tài khoản riêng biệt (nhanvien) và yêu cầu mật khẩu phức tạp.
- Vô hiệu hóa truy cập ẩn danh trong Samba: **guest ok = no, map to guest = bad user** (để chặn đăng nhập sai).

```

h4rrybrwnie@lan20-fileserver:~$ sudo adduser nhanvien
[sudo] password for h4rrybrwnie:
info: Adding user `nhanvien' ...
info: Selecting UID/GID from range 1000 to 59999 ...
info: Adding new group `nhanvien' (1001) ...
info: Adding new user `nhanvien' (1001) with group `nhanvien (1001)' ...
info: Creating home directory `/home/nhanvien' ...
info: Copying files from `/etc/skel' ...
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for nhanvien
Enter the new value, or press ENTER for the default
    Full Name []: employee
    Room Number []: 1
    Work Phone []: 0123456789
    Home Phone []: 0123456789
    Other []:
Is the information correct? [Y/n] Y
info: Adding new user `nhanvien' to supplemental / extra groups `users' ...

h4rrybrwnie@lan20-fileserver:~$ sudo smbpasswd -a nhanvien
New SMB password:
Retype new SMB password:
Added user nhanvien.

```

Cấu hình block [share] trong /etc/samba/smb.conf như sau:

```

[share]
    path = /srv/share
    browseable = yes
    read only = no
    guest ok = no
    valid users = nhanvien
    create mask = 0600
    directory mask = 0700
    public = no

```

create mask = 0600 (Áp dụng cho tệp tin – File)

Tham số này quy định quyền truy cập mặc định đối với mọi tệp tin mới được người dùng tạo ra trong thư mục chia sẻ.

- Người tạo file có quyền đọc và chỉnh sửa nội dung file.

- Nhóm người dùng không có bất kỳ quyền truy cập nào.
- Những người dùng khác hoàn toàn không có quyền.

Ý nghĩa:

Khi một nhân viên tạo file mới (ví dụ: baocao.docx), chỉ duy nhất người tạo file và quản trị viên hệ thống mới có thể mở và chỉnh sửa file đó. Các người dùng khác, dù có quyền truy cập vào thư mục Share, vẫn không thể xem hoặc sửa nội dung file.

Cấu hình này đảm bảo mức độ riêng tư tuyệt đối cho từng tệp tin.

directory mask = 0700 (Áp dụng cho thư mục – Folder)

Tham số này quy định quyền truy cập mặc định đối với mọi thư mục con được tạo mới trong thư mục chia sẻ.

- Chủ sở hữu có toàn quyền: truy cập thư mục, xem danh sách file, tạo, sửa và xóa file bên trong.
- Nhóm người dùng không có quyền truy cập (không thể mở thư mục).
- Người dùng khác không có quyền truy cập.

Mã hóa đường truyền:

Bắt buộc sử dụng giao thức SMBv3 và bật tính năng mã hóa: **smb encrypt = required**.

Việc ép buộc smb encrypt = required sử dụng thuật toán AES-128-GCM/CCM giúp ngăn chặn việc giải mã gói tin bằng Wireshark.

```
[global]
server min protocol = SMB3
smb encrypt = required
```

Nâng cấp phiên bản Samba mới nhất (4.23.x).

```
h4rrybrwnie@lan20-fileserver:~$ smbld -V
Version 4.23.3
```

Kết quả:

Chỉ những người dùng được cấp phát định danh hợp lệ (tài khoản nhanvien) mới có thể thiết lập phiên làm việc với File Server.

```
h4rrybrwnie@h4rrybrwnie:~$ smbclient //192.168.30.10/share -N
session setup failed: NT_STATUS_ACCESS_DENIED
```

Việc thực thi chính sách smb encrypt = required đã kích hoạt thành công thuật toán mã hóa **AES-128-GCM**.

samba version 4.19.5-Ubuntu						
PID	Username	Group	Machine	Protocol Version	Encryption	Signing
165	nhanvien	nhanvien	192.168.40.10 (ipv4:192.168.40.10:53150)	SMB3_11	AES-128-GCM	partial(AES-128-GMAC)

Việc nâng cấp Samba lên phiên bản mới nhất (**4.23.x**) thông qua PPA đã loại bỏ hoàn toàn các đoạn mã lỗi thời.

Kiểm thử cho thấy, ngay cả khi một tài khoản nhân viên bị lộ, Attacker cũng không thể xem hoặc chỉnh sửa các tệp tin thuộc sở hữu của người dùng khác hoặc của quản trị viên (root), giúp khoanh vùng và giảm thiểu thiệt hại khi có sự cố.

Việc tước quyền sudo của tài khoản nhân viên và thiết lập tài khoản quản trị riêng (it_support) đã ngăn chặn thành công kịch bản leo thang đặc quyền cục bộ.

Attacker khi chiếm được máy nhân viên không thể cài đặt thêm các công cụ rà quét mạng (như Nmap, Masscan) hoặc vô hiệu hóa các Agent bảo mật (Wazuh, Antivirus).

Case Study 7: Khắc phục lỗi mất đồng bộ thời gian

Tình huống

Sự cố: Trong quá trình giám logs trên Wazuh, Blue Team phát hiện sự sai lệch thời gian giữa các log gửi từ máy Web Server (LAN10) và File Server (LAN20) so với thời gian thực tế.

Kiểm tra: Thực hiện lệnh **timedatectl status** trên các máy chủ bị cô lập cho kết quả **System clock synchronized: no**.

```
h4rrybrwnie@h4rrybrwnie:~$ timedatectl status
          Local time: Sun 2025-12-14 21:20:42 +07
          Universal time: Sun 2025-12-14 14:20:42 UTC
              RTC time: Sun 2025-12-14 14:20:43
          Time zone: Asia/Ho_Chi_Minh (+07, +0700)
System clock synchronized: no
              NTP service: active
          RTC in local TZ: no
```

Rủi ro: Việc sai lệch thời gian khiến quá trình điều tra trở nên vô nghĩa, không thể xâu chuỗi chính xác trình tự các cuộc tấn công.

Phân tích nguyên nhân

Chính sách cô lập: Các máy chủ trong LAN10 và LAN20 bị Firewall chặn kết nối trực tiếp ra Internet. Do đó, dịch vụ **systemd-timesyncd** mặc định không thể kết nối đến các NTP Pool công cộng (như ntp.ubuntu.com) qua cổng UDP 123.

Thiếu hạ tầng nội bộ: Chưa cấu hình máy chủ thời gian nội bộ (Local NTP Server) để phục vụ các vùng mạng bị cô lập.

Hành động ứng phó

Cấu hình lại máy chủ (Endpoint Configuration):

- Tiến hành sửa đổi file cấu hình **/etc/systemd/timesyncd.conf** trên từng máy chủ.
- Thay đổi máy chủ nguồn (NTP param) trở về Gateway của từng mạng (Ví dụ: Web Server trở về 192.168.10.1, File Server trở về 192.168.30.1).

```
GNU nano 7.2 /etc/systemd/timesyncd.conf
# This file is part of systemd.
#
# systemd is free software; you can redistribute it and/or modify it under the
# terms of the GNU Lesser General Public License as published by the Free
# Software Foundation; either version 2.1 of the License, or (at your option)
# any later version.
#
# Entries in this file show the compile time defaults. Local configuration
# should be created by either modifying this file (or a copy of it placed in
# /etc/ if the original file is shipped in /usr/), or by creating "drop-ins" in
# the /etc/systemd/timesyncd.conf.d/ directory. The latter is generally
# recommended. Defaults can be restored by simply deleting the main
# configuration file and all drop-ins located in /etc/.
#
# Use 'systemd-analyze cat-config systemd/timesyncd.conf' to display the full config.
# See timesyncd.conf(5) for details.

[Time]
NTP=192.168.20.1
FallbackNTP=ntp.ubuntu.com
#RootDistanceMaxSec=5
#PollIntervalMinSec=32
#PollIntervalMaxSec=2048
#ConnectionRetrySec=30
#SaveIntervalSec=60
```

Kích hoạt đồng bộ thời gian

```
h4rrybrwnie@dmz-reverseproxy-waf:~$ sudo timedatectl set-timezone Asia/Ho_Chi_Minh
h4rrybrwnie@dmz-reverseproxy-waf:~$ sudo timedatectl set-ntp on
h4rrybrwnie@dmz-reverseproxy-waf:~$ sudo systemctl restart systemd-timesyncd
```

Cập nhật Firewall Rules cho LAN10, LAN20, LAN30: Cho phép giao thức **UDP Port 123** đi từ LAN Net đến Gateway Address.

✓	0/1 KiB	IPv4 UDP: 14 bytes: 1 KiB	DMZ subnets	*	This Firewall (self)	123 (NTP)	*	none	Allow NTP
---	------------	---------------------------------	----------------	---	----------------------	-----------	---	------	-----------

Kết quả:

- Lệnh `timedatectl status` trả về System clock synchronized: yes.
- Toàn bộ log trên Wazuh đã khớp thời gian thực, đảm bảo tính pháp lý của dữ liệu điều tra.

```
h4rrybrwnie@dmz-reverseproxy-waf:~$ timedatectl status
          Local time: Sun 2025-12-14 22:06:52 +07
        Universal time: Sun 2025-12-14 15:06:52 UTC
              RTC time: Sun 2025-12-14 15:06:52
            Time zone: Asia/Ho_Chi_Minh (+07, +0700)
System clock synchronized: yes
              NTP service: active
          RTC in local TZ: no
```

BÀI HỌC KINH NGHIỆM

Từ quá trình giám sát, phát hiện và ngăn chặn các cuộc tấn công thực tế, nhóm Blue Team đã rút ra những bài học quan trọng để hoàn thiện quy trình vận hành hệ thống cụ thể bên dưới:

Bài học về kiến trúc mạng & Zero Trust

Trong Case Study 3, máy tính nhân viên (LAN30) đã bị xâm nhập và cố gắng quét sang mạng Server (LAN40).

Bài học Blue Team rút ra là:

- Phân vùng mạng là rất quan trọng, việc chia các mạng thành các vùng riêng biệt kết hợp với Firewall Rule chặn là biện pháp hữu ích để ngăn chặn mã độc lây lan diện rộng khi một máy bị chiếm quyền.
- Tư duy Zero Trust: không bao giờ tin tưởng lưu lượng từ mạng nội bộ. Mặc định mọi kết nối giữa các vùng mạng khác là không an toàn và cần phải kiểm tra.

Bài học về bảo mật ứng dụng & cập nhật

Case Study 1 (Shellshock), Case Study 5 (Spring Boot Leak) đều nhắm vào lỗi của ứng dụng Web.

Bài học rút ra:

- Sự cần thiết của cập nhật các bản vá: Việc cập nhật source code hoặc vá lỗi hệ điều hành thường tốn thời gian nhưng rất quan trọng. Trong khi chờ đợi bản vá của hệ thống, WAF đóng vai trò lớn trong việc là lớp khiên bảo vệ tức thời.
- Phòng thủ nhiều lớp: Suricata (IPS) và ModSecurity (WAF) là cần thiết để đảm bảo hệ thống luôn an toàn trước các cuộc tấn công từ bên ngoài.
- Che giấu thông tin: Việc cấu hình Nginx trả về 404 Not Found cho các đường dẫn như /actuator là một kỹ thuật đơn giản nhưng hiệu quả.

Bài học về gia cố hệ thống

Case Study 4 (Docker Escape) và Case Study 6 (Samba) cho thấy nguy cơ từ cấu hình mặc định yếu kém.

Bài học:

- Nguyên tắc đặc quyền tối thiểu: Không bao giờ chạy Container hoặc dịch vụ với quyền root mặc định. Kỹ thuật usersns-remap trong Docker là bắt buộc để ngăn chặn tấn công Container Breakout.
- Bảo vệ dữ liệu nội bộ: Ngay cả trong mạng LAN, dữ liệu chia sẻ phải được mã hóa. Việc sử dụng giao thức SMBv3 và smb encrypt = required là cần thiết để chống lại các cuộc tấn công nghe lén (Sniffing/Man-in-the-Middle) từ nội bộ.

Bài học về giám sát & phản ứng

Trong Case Study 2 (DDOS), hàng loạt IP tấn công dồn dập.

Bài học:

- Vai trò của SIEM: Nếu chỉ nhìn vào log Firewall rời rạc, quản trị viên sẽ bị ngợp. Wazuh giúp tổng hợp hàng trăm log chặ n thành một cảnh báo duy nhất (RULE ID 87702), giúp nhận diện quy mô cuộc tấn công để ứng phó.
- Sự cố sai lệch thời gian ở Case Study 7 cho thấy tầm quan trọng của NTP. Nếu thời gian không đồng bộ, các bản ghi log sẽ trở nên vô giá trị trong quá trình điều tra và truy vết.